

CVEs más relevantes de la semana

Del 26/09/2026 al 03/10/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-89134

Descripción: A certificate with no dNSName SAN but another SAN type present (e.g. registeredID or iPAddress) bypassed the Subject CN dNSName name-constraint check. The CN-as-DNS fallback was gated on `cert->subjectCN != NULL && cert->altNames == NULL && !cert->isCA` instead of "no dNSName SAN", so an out-of-scope CN was accepted. This incomplete fix from CVE-2026-6731, leading to the name-constraint check iss...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-295

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88771

Descripción: Improper input validation vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to an unauthenticated attacker to execute arbitrary commands.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88773

Descripción: Inconsistent interpretation of HTTP requests ('HTTP Request/Response smuggling') vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1-37.279 and NDcPP; Gateway: before 14.1-73.37 FIPS and before 13.1-64.23.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-444

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88775

Descripción: Memory overflow vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading Memory overflow vulnerability leading to unpredictable or erroneous behavior or Denial of Service

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88776

Descripción: Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88777

Descripción: Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-101038

Descripción: A vulnerability was determined in FAST FAC1200R 5.0_20201119_1.0.2. Affected by this vulnerability is the function MmtAtePrase of the component MmtAtePrase Parser. This manipulation causes stack-based buffer overflow. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respon...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101072

Descripción: A vulnerability was identified in Netcore NR289-GE 1.4.5102. This issue affects the function system of the file /ap_ip.cgi of the component CGI Handler. Such manipulation of the argument ip leads to os command injection. The attack can be launched remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101077

Descripción: A flaw has been found in Netcore NR289-GE 1.4.5102. This impacts the function process_request of the component boa_temp Handler. This manipulation causes missing authentication. The attack is possible to be carried out remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101081

Descripción: A security flaw has been discovered in D-Link DI-8400 16.07. This vulnerability affects the function menu_nat_more.asp of the file menu_nat_more.asp of the component Web Administration Service. The manipulation of the argument opt results in stack-based buffer overflow. The attack can be launched remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-100255

Descripción: In JetBrains TeamCity before 2026.2, 2026.1.4, 2025.11.8 administrator account takeover was possible via password reset

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1289

Tecnología: No especificado

Publicado el: 2026-09-30



CVE-2026-100273

Descripción: In JetBrains YouTrack before 2026.2.19197 authorisation bypass in the scripts debugger allowed arbitrary code execution

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-09-30



CVE-2026-100277

Descripción: In JetBrains YouTrack before 2026.2.19197 account takeover was possible by replaying a notification signature

CVSS: 8.9 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-09-30



CVE-2026-102427

Descripción: Joomla Extension - ordasoft.com - Unauthenticated Remote Code Execution in OrdaSoft Joomla CCK < 8.3.16 - site/uploader.php is reached through the component's normal frontend routing (task=getContent), a task with no authentication or ACL check anywhere in the dispatch chain. The handler validates the uploaded file's content with a real magic-byte MIME check, but the extension allow-list that w...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-09-30



CVE-2026-102489

Descripción: Zammad versions 6.3.0 to 6.5.4 are vulnerable a session hijack vulnerability that leads to remote code execution as the zammad user. The vulnerability is also present in version 7.0.0 to version 7.1.3, but not exploitable due to environment conditions.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-384

Tecnología: No especificado

Publicado el: 2026-09-30



CVE-2026-102490

Descripción: All versions of Zammad including the latest alpha enable the local zammad user to escalate privileges to root.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-09-30



CVE-2026-86345

Descripción: A flaw was found in 389-ds-base. The server does not discard plaintext bytes already buffered from a client connection when negotiating StartTLS, allowing an on-path attacker to inject a crafted LDAP message that is processed after the TLS upgrade and whose response is delivered to the client in place of the client's own pending operation's response, due to messageID collision. This can cause a...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-923

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2026-14378

Descripción: The DevKit Pro plugin for WordPress is vulnerable to Authentication Bypass Leading to Administrator Account Takeover in all versions up to, and including, 2.3.0 This is due to the `revert\_switch` handler trusting the attacker-controlled `original\_user\_id` cookie as the privileged identity: `verify\_nonce\_and\_capability()` incorrectly checks the `manage\_options` capability on the user identified ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2026-19660

Descripción: The Divi Membership plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 2.3.0. The `process\_paypal\_callback` function, hooked to the `init` action, accepts a base64-encoded `paypal\_param` GET parameter with no IPN validation, no cryptographic signature check, no ownership verification, and no nonce, allowing it to trust an entirely attacker-controll...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2026-97637

Descripción: The JSON API Auth plugin for WordPress is vulnerable to Authentication Bypass via Cached Session Cookie Disclosure in all versions up to, and including, 3.1.2. The vulnerability exists because the required PI-Media/json-api parent plugin caches controller dispatch results in transients keyed solely by URI and query string, ignoring HTTP method and POST body; this causes the `generate_auth_cooki...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2026-19652

Descripción: The Divi Membership plugin for WordPress is vulnerable to Privilege Escalation in versions up to, and including, 2.2.0. This is due to the `'dmem_form_submit_handler()'` function determining the new user's role by iterating all WordPress roles and calling `'password_verify()'` against an attacker-controlled bcrypt hash supplied in the `'form_id'` POST parameter, with no validation or whitelist of all...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2023-54405

Descripción: H3C CVM, the Cloud Virtualization Management component of the H3C CAS cloud platform, contains an unauthenticated arbitrary file upload vulnerability in the /cas/fileUpload/upload endpoint that allows remote attackers to write arbitrary files by manipulating the caller-supplied token parameter without restricting path traversal or file type. Attackers can exploit the path traversal in the token...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2026-82041

Descripción: UTMStack before 11.2.16 contains a missing authorization vulnerability in UTMIncidentCommandWebsocket.processCommand(), the handler mapped to the /command/{hostname} STOMP destination, where no role check or command allowlist is applied before forwarding supplied commands. Any authenticated user, regardless of role, can send arbitrary operating-system commands over gRPC to any connected agent, ...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2026-82042

Descripción: UTMStack before 11.2.16 contains an authentication bypass vulnerability that allows remote attackers to gain full administrative API access by presenting a valid Utm-Internal-Key header matching the INTERNAL_KEY environment variable value, which the InternalApiKeyFilter accepts for any endpoint without path restriction, constant-time comparison, rate limiting, or audit logging. Attackers who ob...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-02



CVE-2026-87115

Descripción: The VikAppointments Services Booking Calendar plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the extract function in all versions up to, and including, 1.2.21. This makes it possible for unauthenticated attackers to delete arbitrary files on the server, which can easily lead to remote code execution when the right file is deleted (such ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-03



CVE-2026-92084

Descripción: The The Beaver Builder Page Builder – Drag and Drop Website Builder plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 2.11.0.5. This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it possible for unauthenticated attackers to execute arbitrary shortc...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-03



Resumen del Reporte

CVEs analizados: 26

Promedio CVSS: 9.54

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

